



МИНОБРНАУКИ РОССИИ

Федеральное государственное бюджетное образовательное учреждение
высшего образования

«МИРЭА – Российский технологический университет»

РТУ МИРЭА

ЛЕКЦИОННЫЕ МАТЕРИАЛЫ

Системы мониторинга и управления инцидентами информационной безопасности

	<i>(наименование дисциплины (модуля) в соответствии с учебным планом)</i>
Уровень	
	<i>(бакалавриат, магистратура, специалитет)</i>
Форма обучения	
	<i>(очная, очно-заочная, заочная)</i>
Направление(-я) подготовки	
	<i>(код(-ы) и наименование(-я))</i>
Институт	Институт кибербезопасности и цифровых технологий
	<i>(полное и краткое наименование)</i>
Кафедра	Интеллектуальные системы информационной безопасности
	<i>(полное и краткое наименование кафедры, реализующей дисциплину (модуль))</i>
Лектор	к.т.н., Урасков Юрий Леонидович
	<i>(сокращенно – ученая степень, ученое звание; полностью – ФИО)</i>
Используются в данной редакции с учебного года	2022/23
	<i>(учебный год цифрами)</i>
Проверено и согласовано «___» _____ 20__ г.	
	<i>(подпись директора Института/Филиала с расшифровкой)</i>

Москва 2022 г.

Лекция 4. Анализ и состояние рынка SIEM-систем.

ИТ-инфраструктура современных компаний порой весьма разнообразна. При этом, с развитием технологий, главной проблемой построения защиты стало не отсутствие информации, а её обработка. Число источников, обеспечивающих поступление актуальной информации по текущему состоянию защищенности, непрерывно растет. Вместе с увеличением объёма информации, администраторам ИБ всё сложнее отслеживать «общую картину». А ведь если своевременно не анализировать возникающие угрозы и не пытаться предотвратить их, любая система защиты окажется бесполезной. В этих условиях одним из эффективных решений по предотвращению реализаций таких угроз являются системы класса Security Information and Event Management (SIEM).

Кроме того, всё чаще злоумышленники переходят от атак «в лоб» к более сложным и распределённым сценариям (APT – Advanced Persistent Threat). Общие принципы, на которых строится APT, давно известны. К примеру, применение социальной инженерии, чтобы спровоцировать пользователя открыть ссылку или прикрепленный файл. Или использование уязвимостей для получения доступа к атакуемой системе. Проблема же в том, что в случае подобной атаки все средства защиты могут «молчать», так как «вырванные из контекста» инциденты не будут восприниматься в качестве серьёзной угрозы. Но в то же самое время, анализ совокупности инцидентов может явно указать на атаку. Именно эти свойства приписывают современным SIEM-системам – способность обнаруживать атаки по аномалиям, пост-анализу событий и т.д.

Происхождение SIEM

SIEM-системы, как и многие другие продукты появились в результате эволюционного развития и последующего слияния систем SEM и SIM.

SEM (Security Event Management) - системы действуют в режиме приближённом к реальному времени. Для этого им требуется: автоматический мониторинг событий, их сбор, корреляция, генерация предупреждающих сообщений.

SIM (Security Information Management) - системы, в свою очередь, анализируют накопленную информацию со стороны статистики, различных отклонений от «нормального поведения» и т.д. Когда же возможности SIM и SEM объединяются в рамках одного продукта, говорят о SIEM-системах. Исходя из этого, можно дать «литературный» перевод аббревиатуры SIEM – система сбора и корреляции событий.

Важно понимать, что SIEM-системы в качестве самостоятельного (standalone) решения не предназначены и не способны предотвращать инциденты нарушения информационной безопасности. Их сущность заложена в их названии: анализ информации, поступающей из различных источников (DLP, IDS, антивирусы, межсетевые экраны и т.д.), и дальнейшее выявление отклонений от норм по заданным критериям. Тем не менее, «плюсов» вполне достаточно.

Перед системой SIEM ставятся следующие задачи.

- Консолидация и хранение журналов событий от различных источников.
- Предоставление инструментов для анализа событий и разбора инцидентов
- Корреляция и обработка событий по правилам.
- Автоматическое оповещение и инцидент-менеджмент.

Принцип работы SIEM

В теории всё просто: система собирает информацию, анализирует «на лету» (и генерирует предупреждающее сообщение), складывает в базы

данных, анализирует поведение на основании предыдущих наблюдений (и генерирует предупреждающее сообщение).

На практике схема реализуется с помощью соответствующих компонентов:

- Агенты (сбор данных из различных источников);
- Серверы-коллекторы (аккумуляция информации, поступившей от агентов);
- Сервер баз данных (хранение информации);
- Сервер корреляции (анализ информации).

Входной информацией для SIEM-систем может служить практически любая информация. Главное – правильно её подать. Как уже было сказано выше, сбор данных может осуществляться с помощью специальных агентов, которые представляют собой программу, которая локально собирает журналы событий и по возможности передает их на сервер. Для «вычитки» того или иного источника данных агент использует коллекторы - библиотеки для понимания конкретного журнала событий или системы. Коллекторы играют важную роль, так как разные источники могут именовать одно и то же событие по-своему. Например, Firewall одного производителя может записывать в отчёт deny, другого discard, третьего drop, хотя событие одно и то же. Коллекторы помогают привести все эти события к общему знаменателю.

Если же для источника нет соответствующего коллектора, события можно попробовать отправлять как SYSLOG (при условии, что источник умеет это делать). Однако и здесь можно столкнуться с «проблемой синонимов» и необходимостью писать дополнительный обработчик для приведения данных в единый формат.

Также информацию можно собирать удалённо при помощи соединения по протоколам NetBIOS, RPC, TFTP, FTP. Однако в этом случае может возникнуть проблема с нагрузкой на сеть, так как часть систем позволяет передавать только журнал целиком, а не «свежие» записи.

SIEM-системы могут использовать следующие источники информации:

- Access Control, Authentication. Применяются для мониторинга контроля доступа к информационным системам и использования привилегий.
- DLP-системы. Сведения о попытках инсайдерских утечек, нарушении прав доступа.
- IDS/IPS-системы. Несут данные о сетевых атаках, изменениях конфигурации и доступа к устройствам.
- Антивирусные приложения. Генерируют события о работоспособности ПО, базах данных, изменении конфигураций и политик, вредоносном коде.
- Журналы событий серверов и рабочих станций. Применяются для контроля доступа, обеспечения непрерывности, соблюдения политик информационной безопасности.
- Межсетевые экраны. Сведения об атаках, вредоносном ПО и прочем.
- Сетевое активное оборудование. Используется для контроля доступа, учета сетевого трафика.
- Сканеры уязвимостей. Данные об инвентаризации активов, сервисов, программного обеспечения, уязвимостей, поставка инвентаризационных данных и топологической структуры.
- Системы инвентаризации и asset-management. Поставляют данные для контроля активов в инфраструктуре и выявления новых.
- Системы веб-фильтрации. Предоставляют данные о посещении сотрудниками подозрительных или запрещенных веб-сайтов.

Получив информацию, система может её проанализировать. В основе анализа лежит практически «чистая» математика и статистика. Но отправной точкой служат задаваемые вручную правила. К примеру, однократное событие «login failed» ничего не значит, в то время как три и более таких события от

одной учетной записи уже могут свидетельствовать о попытках подбора пароля.

В простейшем случае в SIEM-системах правила представлены в формате RBR (Rule Based Reasoning) и содержат набор условий, триггеры, счетчики, сценарий действий. Например, учитывать параметры удаленности двух последних точек использования банковской карты за небольшой интервал времени: если в 17:00 её использовали для оплаты кофе в Москве, а через 10 минут пытаются снять дневной лимит в Гонконге, то на лицо — попытка мошенничества.

SIEM-системы способны выявлять:

- сетевые атаки во внутреннем и внешнем периметрах;
- вирусные эпидемии или отдельные вирусные заражения;
- попытки несанкционированного доступа к конфиденциальной информации;
- мошенничество;
- ошибки и сбои в работе информационных систем;
- уязвимости;
- ошибки конфигураций в средствах защиты и информационных системах;
- целевые атаки (APT).

Анализ рынка SIEM-систем

Мировой рынок SIEM

Мировой рынок SIEM подвержен стагнации: с 2019 по 2020 годы наблюдается незначительный рост с 3,55 до 3,58 млрд долларов (аналитика Gartner рисунок 1). Поскольку этап широкого внедрения прошёл, потребители заинтересованы в росте аналитики и расширении числа систем — источников информации. В частности, по-прежнему высока неудовлетворённость потребителей в связи с недостаточной эффективностью обнаружения целевых атак и взломов и реагирования на них. Правильное использование аналитики

по угрозам и профилей поведения может повысить эффективность обнаружения и, следовательно, удовлетворить потребителей. Разработчики SIEM-систем продолжают улучшать возможности расследования и реагирования за счёт встроенных функций с дополнительными технологиями, такими как EDR, NDR и SOAR. Мировой рынок SIEM характеризуется небольшим количеством поставщиков с большой клиентской базой. Ключевые производители (Splunk, Micro Focus, IBM и LogRhythm) удовлетворяют потребности 32 % пользователей, в то время как 68 % распределены между остальными игроками рынка. Появление новых интеграций и средств аналитики позволит производителям обогнать конкурентов и привлечь новых покупателей.



Рисунок 1 – Квадрант Гартнера (Мировой рынок SIEM-систем)

Наиболее популярные иностранные SIEM-системы, представленные в России:

- IBM QRadar SIEM;
- McAfee Enterprise Security Manager;
- Micro Focus ArcSight 2021.1;

Российский рынок SIEM

Российский рынок SIEM-систем продолжает развиваться. Недавно на него вышел новый игрок, «Лаборатория Касперского», с продуктом Kaspersky Unified Monitoring and Analysis Platform, в то время как Splunk официально его покинул. Представлены и бесплатные аналоги, но их использование усложняется необходимостью их индивидуализации и доработки под конкретного потребителя. В связи с этим в России появились вендоры, которые способны обеспечить необходимую доработку бесплатных SIEM под цели клиента, предоставить поддержку и надлежащую экспертизу. Набирающая популярность в мире модель SIEMaaS (SIEM как услуга) пока не представлена на российском рынке, поскольку заказчики в ней не заинтересованы. Вендоры занимаются анализом этого направления, продумывают работу такой платформы и отслеживают факторы, которые могут создать потребность в ней. За прошедшие годы наблюдается снижение доли иностранных SIEM на отечественном рынке. Это связано во многом с политикой импортозамещения и ростом популярности российских продуктов, а также с появлением новых поставщиков. Кроме того, один из крупнейших производителей SIEM в мире, как было отмечено выше, официально ушёл от нас.

В связи с этим на российском рынке представлены в основном отечественные продукты:

- MaxPatrol SIEM (Positive Technologies);
- Ankey SIEM («Газинформсервис»);
- Kaspersky Unified Monitoring and Analysis Platform («Лаборатория

- Касперского»);
- KOMRAD Enterprise SIEM (НПО «Эшелон»);
- RuSIEM (ООО «РусИЕМ»);
- «СёрчИнформ SIEM» («СёрчИнформ»).

Альтернатива SIEM-системам

Сложность и стоимость покупки и эксплуатации SIEM, а также появление новых аналитических технологий в области безопасности развивают интерес пользователей к альтернативным способам выявления атак и реагирования на них:

- Платформы сбора и анализа событий. Эти продукты могут закрывать некоторые функции SIEM и, возможно, реализовывать другие варианты использования, не связанные с безопасностью.
- Платформы для расширенного обнаружения и устранения угроз (XDR). Они представляют собой интегрированные наборы продуктов для конечных точек, сетей и облаков. Поставщики настраивают их для обеспечения автоматического обнаружения угроз и реагирования на них. Платформы XDR могут предоставлять тщательно отобранные, в основном «автоматические» возможности обнаружения и реагирования тем организациям, которые придерживаются моновендорного подхода. Есть также мнение, что по мере развития технологии XDR некоторые поставщики, такие как FireEye, Gurukul, McAfee и Securonix, начинают рассматривать своё решение SIEM как часть предложения XDR.
- Управляемые службы обнаружения и реагирования. Основное внимание здесь уделяется расследованию, проверке и предоставлению рекомендаций по локализации и исправлению происшествий, а не передаче клиенту упорядоченных предупреждений. Всё чаще поставщики готовы предлагать (а клиенты — принимать) действия

направленные на сдерживание или прерывание событий в области безопасности. Обычно это достигается через конечные точки или сетевые средства управления. Такие поставщики различаются по своим способностям контролировать набор средств управления безопасностью клиента и собирать журналы для составления отчётов о соответствии требованиям.

Выводы

SIEM — это система не только для ИБ. Ошибки и сбои в операционных системах, сетевом оборудовании, ПО — информацию обо всем об этом сотрудники IT-отдела могут почерпнуть в SIEM.

SIEM — весьма непростое решение для процесса управления журналами, к тому же достаточно дорогостоящее для внедрения в малом и среднем бизнесе. Для его эксплуатации необходимо иметь как минимум одного квалифицированного сотрудника, который будет обеспечивать контроль непрерывности сбора событий, управлять правилами корреляции, корректировать и обновлять их с появлением новых угроз и в соответствии с изменениями в инфраструктуре. Установка SIEM в качестве «черного ящика» с активацией всех предустановленных правил корреляции без надлежащего контроля и управления приведет к растрате бюджета организации.

Однако при успешном внедрении SIEM-системы в организации будут получены следующие возможности:

- корреляцию и оценку влияния IT- и ИБ-событий и процессов на бизнес;
- SOC с анализом ситуации в инфраструктуре в режиме реального времени;
- автоматизацию процессов обнаружения угроз и аномалий;
- автоматизацию процессов регистрации и контроля инцидентов;
- аудит политик и стандартов соответствия, контроль и отчетность;

- задокументированное корректное реагирование на возникающие угрозы ИБ и ИТ в режиме реального времени с приоритезацией в зависимости от влияния угроз на бизнес-процессы;
- возможность расследования инцидентов и аномалий, в том числе произошедших давно;
- доказательную базу для судебных разбирательств;
- отчетность и показатели (KPI, ROI, управление событиями, управление уязвимостями).

Мировой рынок SIEM за последние годы сильно консолидировался, на нем появились группа признанных лидеров, а также около десяти догоняющих их или нишевых игроков. В России до недавнего времени были представлены практически все лидирующие производители SIEM-систем. Также появилось достаточное количество сертифицированных отечественных решений, не уступающих по своим возможностям зарубежным конкурентам. Поэтому потенциальный заказчик в России без особо труда сможет выбрать оптимальную для себя SIEM-систему с нужным набором функций.